Technical Seminar Report

On

Threat Modeling for Security Testing: A Purple Team Framework

Submitted to

Jawaharlal Nehru Technological University, Hyderabad

In Partial Fulfillment of the requirements for the Award of Degree of

BACHELOR OF TECHNOLOGY
IN
CYBER SECURITY

Submitted
By

N.Ramesh

(218R1A6246)

Under the Esteemed guidance of

Mrs.R.Malar

Associate Professor, Department of CS

Department of Cyber Security

CMRENGINEERINGCOLLEGE

(Approved by AICTE, NEW DELHI, Affiliated to JNTU, Hyderabad)
Kandlakoya, Medchal Road, R.R. Dist. Hyderabad-501 401

2024-2025

CMRENGINEERINGCOLLEGE

(Accredited by NBA, Approved by AICTE NEW DELHI, Affiliated to JNTU, Hyderabad)

Kandlakoya, Medchal Road, Hyderabad-501 401

Department of Cyber Security

CERTIFICATE

This is to certify that the seminar entitled **"Threat Modeling for Security Testing: A Purple Team Framework""**is a bonafide work carried out by

N.RAMESH (218R1A6246)

In partial fulfillment of the requirement for the award of the degree of **BACHELOR OF TECHNOLOGY** in **CYBER SECURITY** from CMR Engineering College, affiliated to JNTU, Hyderabad, under our guidance and supervision. The results presented in this seminar have been verified and are found to be satisfactory. The results embodied in this seminar have not been submitted to any other university for the award of any other degree or diploma.

Internal Guide	Seminar Coordinator	Head of the Department
Mrs.R.Malar	**Mr. M. Ramasamy**	**Dr.M.Ashwitha Reddy**
Associate Professor	Assistant Professor	Prof & H.O.D
Department of CS	Department of CS	Department of CS
CMREC, Hyderabad	CMREC, Hyderabad	CMREC, Hyderabad.

ACKNOWLEDGMENT

We are extremely grateful to **Dr. A. Srinivasula Reddy**, Principal and **Dr. M. Ashwitha Reddy**, **HOD**,**Department of CSC, CMR Engineering College** for their constant support**.**

I am extremely thankful to **Mrs.R.Malar,** Associate Professor, Internal Guide, Department of CSE, for her constant guidance, encouragement and moral support throughout the Technical seminar. I will be failing in duty if I do not acknowledge with grateful thanks to the authors of the references and other literatures referred in this seminar. I express my thanks to all staff members and friends for all the help and co-ordination extended in bringing out this Technical seminar successfully in time.

Finally, I am very much thankful to my parents who guided me for every step.

Date: **N.RAMESH**
Place: Hyderabad **(218R1A6246)**

TABLE OF CONTENTS

CHAPTER NAME	PAGE NO
1.INTRODUCTION	**1-2**
1.1 Objective	2
2.ROLES & RESPONSIBILTIES	**3-5**
2.1 Executive Summary	3
2.2. Red Team (off-sec)	3
2.3 Security Operations Center (Blue Team)	4
2.4 DFIR (Blue Team)	4-5
3. CYBER THREAT INTELLIGENCE	**6-11**
3.1 Target Environment Assessment	6-7
3.2 Threat Actor Selection & Prioritization	7-8
3.3 Cyber Threat Landscape Research	8
3.4 Tactics, Techniques, & Procedures Extraction	9-10
3.5 Analyze and Table Top TTPs	10-11
4. PREPARATION & INFRASTRUCTURE	**12-16**
4.1 Exercise Environment Setup	12-14
4.2 Blue and Red Team Readiness	14-15
4.3 Retesting	15-16
5. ENHANCEMENTS & FUTURE WORK	**17**
6. CONCLUSION	**18-20**
6.1 Exercise Workflow & Tracking	18-20
7. REFERENCES	**21**

LIST OF FIGURES

FIGURE NO.	PAGE NO.
Fig 1: SOC Workflow	09
Fig 2: Threat Based Security Approach	05
Fig 3: Atomic Purple Team Lifecycle	08
Fig 4: David Bianco’s Pyramid of Pain.	08
Fig 5: PT Infrastructure	10
Fig 6: Hunt & Defend Framework	14

CHAPTER 1

INTRODUCTION

A Purple Team is a collaborative unit that integrates the efforts of Red Teams and Blue Teams, creating a synergistic approach to cybersecurity. The Red Team is responsible for emulating adversarial behavior, simulating attacks to identify vulnerabilities within the organization's defenses. In contrast, the Blue Team focuses on defending against these attacks, monitoring systems, and responding to incidents. The essence of a Purple Team lies in its ability to bridge the gap between offensive and defensive strategies, fostering a culture of collaboration and continuous improvement.

Purple Team Exercises are structured engagements designed to enhance the organization's security posture through a series of well-defined steps. At the outset of a Purple Team Exercise, the Cyber Threat Intelligence team, Exercise Coordinator, or Red Team presents the adversary, along with relevant Tactics, Techniques, and Procedures (TTPs) that are pertinent to the organization's threat landscape. This initial presentation sets the stage for a collaborative discussion among attendees, where security controls and expectations for the TTPs are thoroughly examined. The Red Team then emulates the TTPs in a controlled environment, allowing the Blue Team, including the Security Operations Center (SOC), Hunt Team, and Digital Forensics and Incident Response (DFIR) analysts, to follow established processes to detect and respond to the simulated attacks. This real-time interaction not only enhances the Blue Team's detection capabilities but also provides valuable insights into the effectiveness of existing security measures.

Cycle of emulation, detection, and adjustment fosters a proactive security culture, where both teams learn from each engagement and continuously refine their strategies.The goals of Purple Team Exercises are driven by specific needs that arise within the organization. These exercises may be initiated for various reasons, including testing attack chains against a target organization, training the Blue Team to enhance their defensive skills, evaluating TTPs that have not been previously tested, and assessing the processes between security teams. Additionally, Purple Team Exercises serve as preparation for zero-knowledge Red Team engagements, where the Blue Team is unaware of the attack simulations. By conducting these exercises, organizations can foster a collaborative culture that encourages knowledge sharing and teamwork among security professionals.

Furthermore, the methodology employed in Purple Team Exercises is closely aligned with zero-knowledge Adversary Emulations, emphasizing the importance of Cyber Threat Intelligence against current threats but also prepares it for future challenges in the dynamic cybersecurity landscape.

1.1 OBJECTIVE

The Purple Team Exercise Framework (PTEF) is designed to establish a structured approach for developing a comprehensive Purple Team Program. This framework emphasizes the importance of adversary emulations conducted through Purple Team Exercises and Continuous Purple Teaming Operations. A Purple Team consists of a collaborative group of cybersecurity professionals from various disciplines, including:

- **Cyber Threat Intelligence Team**: Responsible for researching and providing actionable threat intelligence, including Tactics, Techniques, and Procedures (TTPs).
- **Red Team**: The offensive unit tasked with simulating adversary behaviour to test the organization's defence.
- **Blue Team**: The defensive unit, which includes the Security Operations Center (SOC), Hunt Team, Digital Forensics and Incident Response (DFIR), and/or Managed Security Service Providers (MSSP).

Unlike traditional Red Team engagements, which are conducted without the Blue Team's prior knowledge, Purple Team Exercises are characterized by transparency and collaboration. In these exercises, the Blue Team is informed about the attack activities as they unfold, fostering a real-time dialogue between the Red and Blue Teams. This hands-on approach allows both teams to engage in open discussions regarding attack techniques and defensive strategies, ultimately enhancing the organization's security posture.

Purple Team Exercises are driven by Cyber Threat Intelligence and focus on emulating the TTPs of known malicious actors that pose a threat to the organization. The primary goal is to identify and address vulnerabilities within the security framework, thereby strengthening the overall resilience against cyber threats.

CHAPTER 2

ROLES & RESPONSIBILTIES

Effective Purple Team exercises rely on the active planning and participation of a broad range of Red and Blue Team members across four key phases: Cyber Threat Intelligence Integration, Exercise Design and Preparation, Exercise Execution, and Post-Exercise Review and Lessons Learned. It is crucial that participants are identified and clearly informed of their specific roles and responsibilities as early as possible in the Exercise Design and Preparation phase to ensure a successful and productive outcome. This includes not only defining individual tasks but also fostering a collaborative environment where team members can effectively communicate, share insights, and learn from each other throughout the entire exercise lifecycle

2.1 Executive Summary

Approval and support for the Purple Team Exercise must be obtained from management across all participating functions. This includes endorsement of the exercise's goals, budget, and scope before any further preparations or phases can commence. Once management has granted approval, operational managers are required to give their consent as the exercise is likely to affect ongoing operations. Analysts who typically have daily responsibilities will need to concentrate on the exercise during this time. It is the responsibility of operational managers to select participants from their teams for the exercise and to relieve them of their regular duties throughout the duration of the exercise.

2.2.Red Team (off-sec)

The Red Team's involvement in Purple Team exercises is twofold, encompassing both meticulous preparation and active participation during the execution phase, necessitating a substantial time investment. The preparatory phase, in particular, requires a degree of focused effort akin to the extensive planning undertaken in a zero-knowledge Red Team engagement. This underscores the importance of dedicated preparation time for the Red Team to effectively fulfill their responsibilities. To facilitate this, operational managers should recognize the significance of this preparatory period and prioritize it by temporarily reassigning or relieving Red Team members from other operational tasks. This dedicated time allows the Red Team to thoroughly analyze the threat intelligence provided, develop realistic attack scenarios, configure their tools and infrastructure, and coordinate their actions.

2.3.Security Operations Center (SOC)

The Manager of the Security Operations Center (SOC) should ensure their attendance at the exercise and facilitate the participation of SOC analysts. While minimal involvement is anticipated from the SOC during the Preparation phase, it is crucial that analysts present during the Exercise Execution are fully focused on the task at hand. SOC management should make appropriate arrangements by relieving exercise participants of their regular responsibilities. Additionally, other analysts should be assigned to cover global operations during the absence of those attending the exercise.

For organizations that do not have an in-house Security Operations Center and instead utilize Managed Security Service Providers (MSSP), it is still possible to conduct Purple Team Exercises. However, this will necessitate careful planning and obtaining approval from the MSSP to confirm their participation in the exercise.

Fig1:2.3.1 SOC Workflow

2.4.Digital Forensic & Incident Response (DFIR)

Digital Forensics and Incident Response (DFIR) analysts are also expected to take part in the Purple Team Exercise. While minimal involvement is anticipated from DFIR teams during the Preparation phase, it is essential that the analysts present during the Exercise Execution are fully engaged. DFIR Managers should ensure that all

incident cases are reassigned or paused for those attending the exercise, allowing them to maintain their regular workflow without any impact on their performance. Digital Forensics is both a field of science and a field of art. It has no deterministic technical procedure to provide a step-by-step guide that will lead the analyst directly to the answer. A lot of training and practice are needed to reach a proficient skill level. Therefore, the goal of this document is to provide the fundamental tools and techniques that will help to build specific OT Digital Forensics capabilities, while a high level of skill can be achieved after continued practice and training

- If the organization has a Hunt Team, they should participate, as well. Very little time is expected from the Hunt Team in the Preparation phase but the full attention of analysts in attendance is required during the Exercise Execution. The Hunt Team Manager should share their most up-to-date Playbooks during the Preparation Phase of DFIR to ensure ideal TTPs are chosen for the exercise

DFIR service is supported by various capabilities that include the 4-Hour Remote Service Level Agreement (SLA) with a Retainer, which ensures prompt deployment of investigative tools and expert responders for businesses dealing with cybersecurity incidents. Additionally, eSentire provides critical visibility by deploying both commercially available and open-source tools, including eSentire's network, endpoint, and log technology, as necessary. This deployment aims to collect endpoint telemetry, full network packets, NetFlow, and log data from both on-premises and cloud environments. This multi-faceted approach enables a thorough examination of the situation from various vantage points, enhancing the depth and accuracy of the analysis process. •Digital Forensics and Incident Response Services detected elements, enabling the generation of comprehensive and detailed reports. Along with malware analysis, digital forensic analysis is an important feature.

CHAPTER 3

CYBER THREAT INTELLIGENCE

The methodology outlined for utilizing Cyber Threat Intelligence in Purple Team Exercises draws inspiration from a presentation by Katie Nickels and Cody Thomas at the SANS Threat Hunting & Incident Response Summit on September 6, 2018, titled "ATT&CKing the Status Quo: Threat-Based Adversary Emulation with MITRE ATT&CK." Additionally, MITRE offers free training resources, such as "Using ATT&CK for Cyber Threat Intelligence Training." The accompanying graphics were designed by Erik van Buggenhout of NVISO

.

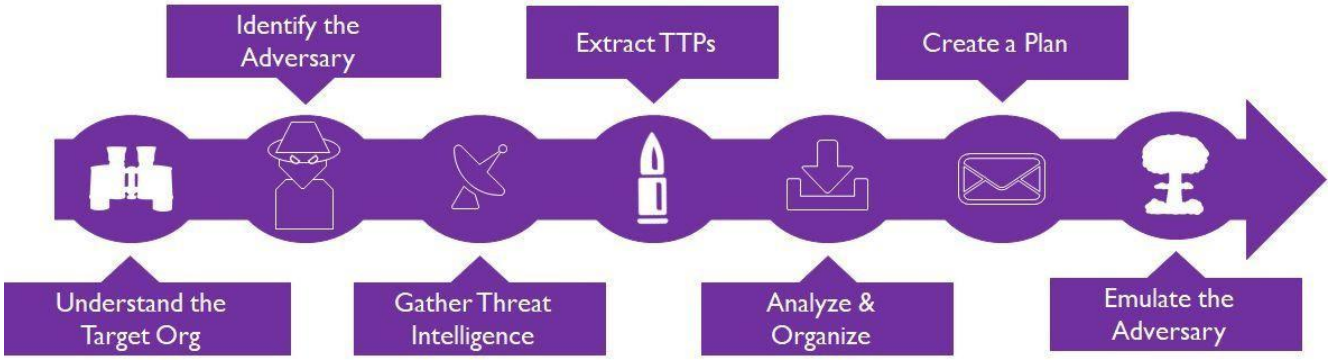


Fig2: 3.0.1Threat Based Security Approach

3.1 Target Environment Assessment

Regardless of whether you are a consulting firm conducting Cyber Threat Intelligence or part of an internal team, it is essential to thoroughly understand the target organization. To achieve this understanding, the Cyber Threat Intelligence provider should conduct a comprehensive assessment similar to the preparatory exercises that threat actors typically perform before launching an attack from outside the network. The aim is to create a detailed preliminary profile of the organization, highlighting its vulnerabilities from the perspective of potential attackers. This insight will help contextualize the Cyber Threat Intelligence and assist in the formulation of attack chains or scenarios for the Cyber Threat Intelligence Report. The organization should contribute relevant information through interviews and discussions. The result of this process is the identification of attack surfaces associated with the organization’s people, processes, and technologies.

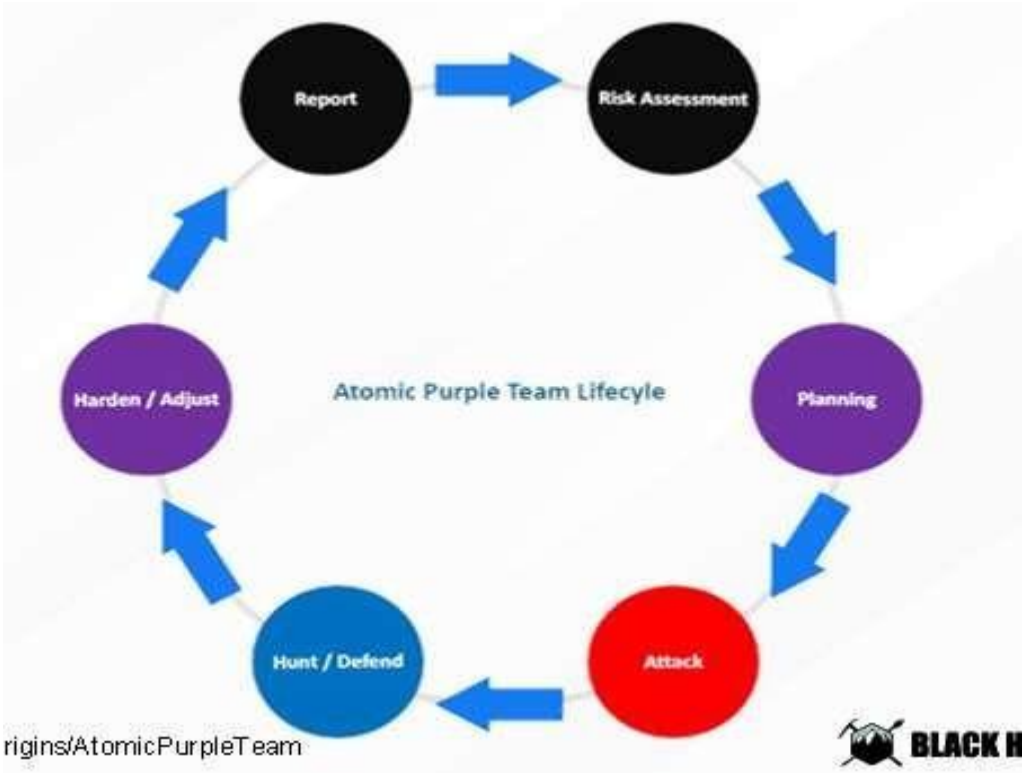


Fig3: 3.1.1 Atomic Purple Team Lifecycle

A threat assessment is a systematic process used to identify, evaluate, and prioritize potential threats to an organization's assets, operations, and personnel. It involves analyzing various factors, including the likelihood of threats occurring, their potential impact, and the vulnerabilities within the organization. By gathering intelligence on known adversaries, their tactics, techniques, and procedures (TTPs), organizations can better understand the risks they face. The assessment informs decision-making and resource allocation, enabling organizations to implement effective security measures and response strategies. Ultimately, a thorough threat assessment enhances an organization's resilience against evolving threats and improves overall security posture.

3.2 Threat Actor Selection & Prioritization

When considering who is targeting the organization, it is essential to evaluate the adversary's capability, intent, and opportunity in the context of Purple Team Exercises. For organizations new to Adversary Emulations, it is advisable to begin with less sophisticated threat actors and gradually progress to more advanced ones as the Purple Team Program develops.

- **Intent**: Intent is fundamentally linked to impact and is largely determined by the industry in which the

organization operates. Generally, adversaries aim for data theft, but their specific goals can vary with each intrusion or actor. For example, an adversary might seek to compromise operational details of a campaign or technical specifications of a product. Intent is not something that can be influenced.

• **Opportunity**: Opportunity relates to the timing and understanding of the target environment. While it can sometimes align with vulnerabilities, this is not always the case. For instance, having a product with a 0-day vulnerability is one aspect, but the risk increases significantly if the adversary is aware of it. Additionally, certain periods, such as a company's benefits open enrollment, may present ideal opportunities for targeted attacks using socially-engineered emails.

• **Capability**: Capability refers to the adversary's ability to successfully achieve their objectives and exploit opportunities. This is influenced by various factors, including the adversary's skills and the resources they possess, whether financial, human, or technical. For example, even if a target is vulnerable and the adversary intends to exploit a 0-day vulnerability to steal data, the risk diminishes if the adversary lacks the means to create or acquire the necessary exploit.

3.3 Cyber Threat Landscape Research

The cyber threat landscape refers to the dynamic environment of potential threats and vulnerabilities that organizations face in the digital realm. This landscape is constantly evolving due to advancements in technology, changes in cybercriminal tactics, and the emergence of new vulnerabilities. Researching the cyber threat landscape involves analyzing various factors, including the types of threats, the motivations behind them, and the techniques employed by adversaries.

Key components of this research include identifying prevalent threat actors, such as nation-states, hacktivists, and cybercriminal organizations, each with distinct goals and capabilities. Understanding their tactics, techniques, and procedures (TTPs) is crucial for organizations to anticipate and mitigate potential attacks. Additionally, the research examines the impact of emerging technologies, such as artificial intelligence and the Internet of Things (IoT), which can introduce new vulnerabilities and attack vectors.

Organizations must also consider the regulatory and compliance landscape, as legal requirements can influence their cybersecurity strategies. By conducting thorough cyber threat landscape research, organizations can develop proactive security measures, enhance their incident response capabilities, and foster a culture of cybersecurity awareness. Ultimately, this research is essential for building resilience against evolving cyber threats and protecting critical assets in an increasingly interconnected world.

By staying informed about the latest trends and developments in the cyber threat landscape, organizations can better prepare for and respond to potential security incidents, thereby safeguarding their operations and reputation.

3.4 Tactics, Techniques, & Procedures (TTPs)Extraction

Cyber Threat Intelligence can be sourced from various avenues, including open source intelligence, third-party vendors, or developed internally within the organization. It is crucial to utilize multiple sources and consider industry-specific resources, such as Information Sharing and Analysis Centers (ISACs), to enhance the quality and breadth of the intelligence gathered. There are several types of Cyber Threat Intelligence, as illustrated in David Bianco's Pyramid of Pain.

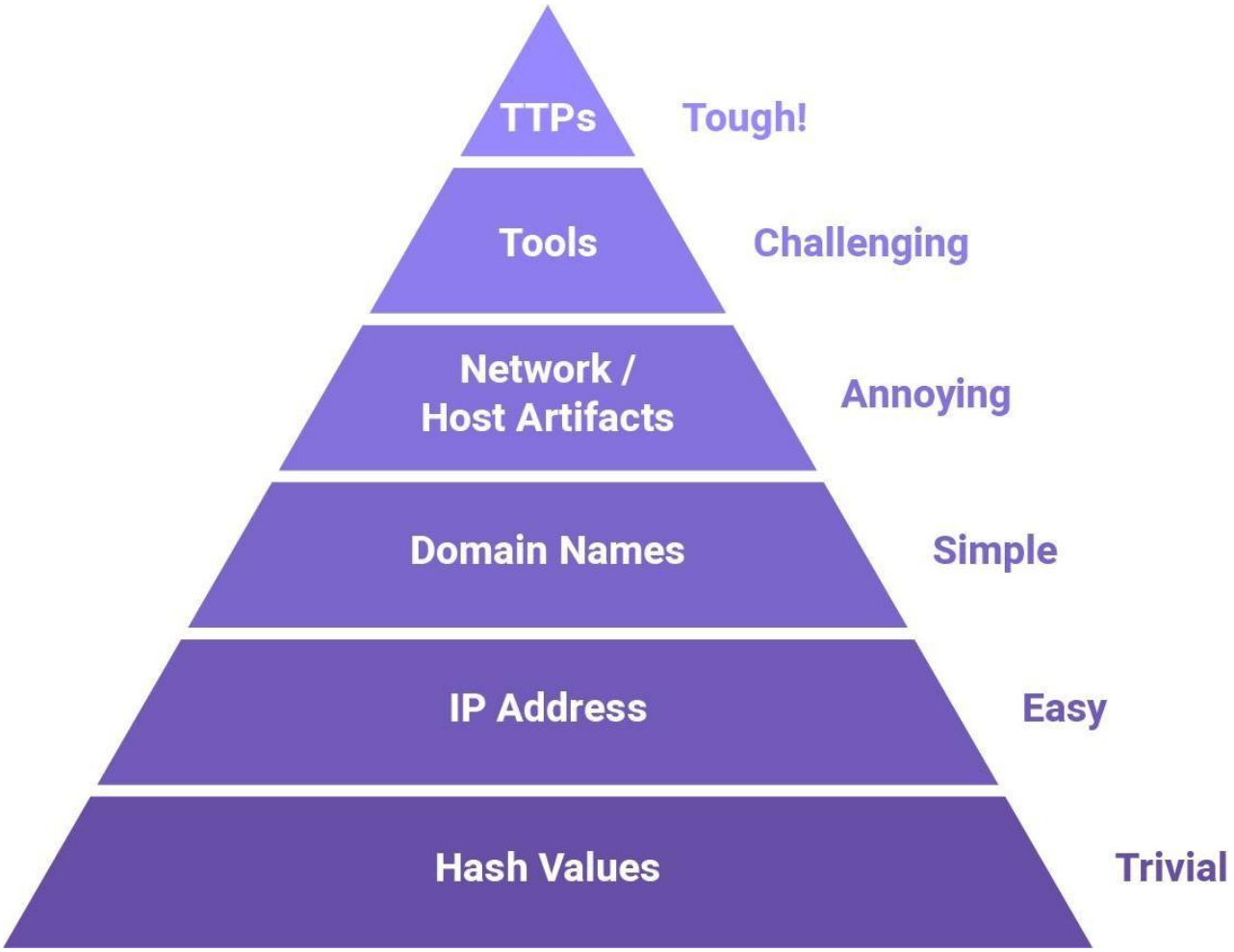


Fig 4 : 3.4.1 David Bianco's Pyramid of Pain.

The most relevant type of Cyber Threat Intelligence for conducting Adversary Emulation and Purple Team Exercises resides at the top of the Pyramid of Pain:

- **Tactics, Techniques, and Procedures (TTPs):** This refers to the methods adversaries use to achieve their objectives, encompassing the entire process from initial access to data exfiltration and impact. This is where mapping to the MITRE ATT&CK framework becomes essential.

- **Tools:** These are the software applications utilized by adversaries to fulfill their goals. They can include custom malware, open-source tools, or legitimate software that is misused (often referred to as "Living off the Land"). A comprehensive list of Command and Control frameworks and tools can be found in The C2 Matrix.
- **Host Artifacts**: These are observable indicators resulting from adversary activities on one or more hosts. Examples include modified or created registry keys and values, files, directories, and services.

3.5 Analyze and Table Top TTPs

At this stage, Cyber Threat Intelligence analysts should extract Tactics, Techniques, and Procedures (TTPs) from the acquired Threat Intelligence and map them to a framework such as MITRE ATT&CK, which is the industry standard for identifying and documenting common adversary TTPs. While TTPs are often grouped together as a single entity referred to as “the adversary’s TTPs,” they actually represent three distinct aspects of adversary behavior at varying levels of abstraction. Tactics are high-level strategies aimed at achieving specific goals (e.g., Initial Access, Exfiltration). Techniques and sub-techniques (introduced in July 2020) provide more detail on how these goals are accomplished (e.g., Spear Phishing a link, Credential Dumping). Procedures represent the specific steps taken to achieve these goals.

Developing an Adversary Profile is an effective way to create a high-level plan for how the Red Team will conduct the exercise. The objective is to produce a straightforward document that outlines what the Red Team will emulate. This can be presented in a simple table format. MITRE has created the ATT&CK Navigator, a web application that dynamically represents ATT&CK techniques. This tool allows users to select specific techniques based on a threat group or software, enabling modifications and annotations. It may also include TTPs assigned to an adversary that were not provided in the Cyber Threat Intelligence. Importantly, the techniques for Groups/Software in the Navigator are fully referenced to open sources on the MITRE ATT&CK Groups and Software pages. The Navigator is open-source and can be self-hosted.

Sponsors and Managers of the teams should review the TTPs provided by Cyber Threat Intelligence and conduct a table-top exercise to select the TTPs that will be emulated during the Purple Team Exercise. The sooner the TTPs are selected, the earlier the Preparation phase can commence. The chosen TTPs should be actively utilized by malicious actors targeting the organization and integrated into attack chains. Additionally, new TTPs may be introduced, which are particularly suitable for Continuous Purple Team Operations.

A management-level meeting should be held to discuss the expected controls for these TTPs and determine which teams should have visibility into TTP activities. The selected TTPs for the exercise

should be categorized as follows:

- **TTPs that are not blocked or prevented:** These TTPs may provide limited value during the exercise, as they can be easily executed without detection. However, emulating them can be beneficial to highlight specific vulnerabilities or weaknesses in the organization's defences. This can raise awareness among stakeholders about potential risks and prompt discussions on necessary improvements to security measures.
- **TTPs that may be logged**: TTPs that are likely to be logged are particularly valuable for training hunt teams. By simulating these techniques, organizations can assess the effectiveness of their logging mechanisms and improve their detection capabilities. This exercise allows detection engineers to refine alerting processes, ensuring that relevant events are captured and analyze, ultimately enhancing the organization's overall security posture.
- **TTPs that may trigger alerts**: TTPs that are known to trigger alerts are essential for training Security Operations Center (SOC) analysts. By practicing with these techniques, analysts can learn to respond effectively to real-world incidents. This training helps test and validate defensive processes, ensuring that the SOC is prepared to take appropriate action when alerts are generated, thereby improving incident response times and overall security effectiveness.

CHAPTER 4

PREPARATION & INFRASTRUCTURE

Once the attendees have been selected, the logistics planning can commence. Choosing the right location for Purple Team Exercises is crucial, as travel considerations can significantly impact the execution of the exercises. Ideally, the location should be within the Security Operations Center (SOC), where SOC, Hunt Team, and/or Digital Forensics and Incident Response analysts are available. If travel is not feasible, Purple Team Exercises can be conducted remotely using video conferencing tools. It is important to select a video conferencing solution that aligns with your threat model, keeping in mind various attack techniques that may be relevant.

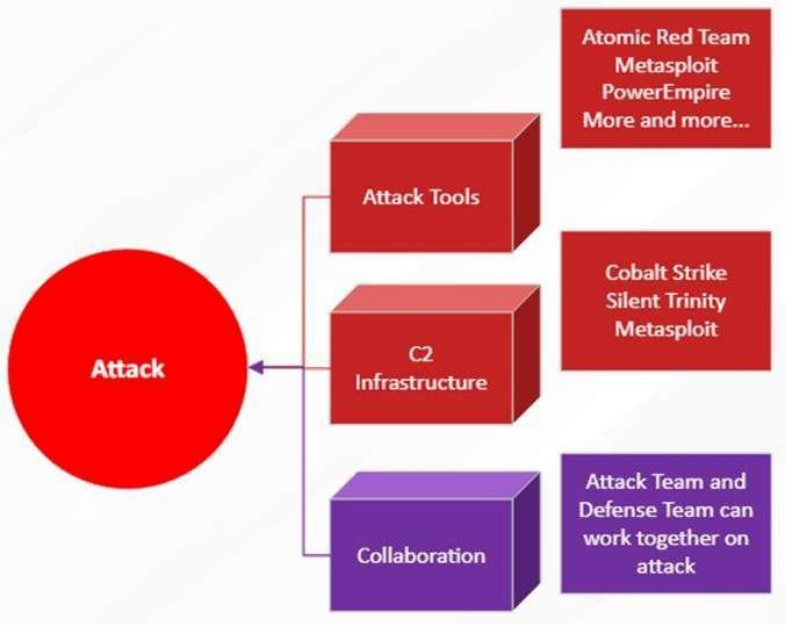
Standard procedures must be followed to secure travel approvals, which should be completed at least one month prior to the Purple Team Exercise to ensure that all necessary attendees are authorized. Participants should plan to arrive the day before the exercise begins to facilitate a timely setup in the exercise environment.

A dedicated conference room with adequate space for all attendees, sponsors, observers, and their equipment is essential for the duration of the week. Changing locations during the week can hinder exercise progress, as technology will need to be retested, and attendees may struggle to locate the new venue. While a training room can be utilized for the exercise, sharing screens via a projector or TV may not be as effective as using the technology available in conference rooms. Each participant should arrive with a workstation equipped with media output capabilities (HDMI, DVI, and VGA) to facilitate quick screen sharing. If the exercise is conducted remotely, screen sharing should be straightforward with the chosen video conferencing solution.

5.1 Exercise Environment Setup :

The Exercise Coordinator should collaborate with stakeholders to identify and provision target systems in production that align with the approved goals of the Purple Team Exercise and the adversary emulation plan. Production systems provide the most accurate representation of the operational environment, as they should have security tools reporting to production dashboards, allowing for effective testing of processes.

Based on the established goals and TTPs, requests for target systems should follow standard procedures to ensure consistency with production systems:



Attack Infrastructure

The Red Team is tasked with establishing the attack infrastructure for the Purple Team Exercise, which may be internal or external depending on the Tactics, Techniques, and Procedures (TTPs) being emulated. This process includes acquiring the necessary tools to replicate adversary behaviours and TTPs.

External Infrastructure

Select and procure an external hosting provider. Create external virtual machines:

Allow connections only from the target organization's outbound IP addresses and Red Team IP addresses. Set up credential theft sites and/or payload delivery sites. Establish Command and Control (C2) infrastructure based on the payloads and TTPs. Configure redirectors and relays. Ensure that SMTP servers permit sending emails into the organization :Allow access to shared email services .If new SMTP servers are being used, additional time may be needed to build their reputation. Purchase necessary domains. Generate or acquire TLS certificates.S et up domain fronting if required. Categorize domains or ensure that proxies and outbound controls allow access provide IP addresses and domains to the Blue Team if testing is to occur prior to the exercise. Test payloads and domains with the Blue Team Manager to confirm that allowlists are complete and that payloads/C2 are functioning correctly. This testing should be conducted on test systems, not the same systems used for the exercise.

Internal Infrastructure

- Create internal virtual machines for attack simulations. Ensure that these machines are whitelisted

on Network Access Control solutions. Set up C2 infrastructure based on the payloads and TTPs. payloads with the Blue Team Manager to ensure that the payloads/C2 are operational. This should also be done on test systems, separate from those used in the exercise.

5.2 Blue and Red Team Readiness

Red Team Preparation

- Set up at least two systems to demonstrate attack activity .Confirm that the attack infrastructure is fully operational. Ensure that target systems are accessible and functional. Document all commands necessary to emulate TTPs in a playbook. Create resource scripts or frameworks to generate payloads and set up handlers. Test TTPs on different hosts than those designated for the exercise, ensuring they are configured identically.

Blue Team Preparation

- Validate that security tools are reporting correctly to production security systems from the target systems. Ensure that the attack infrastructure is accessible through proxy and outbound controls.
- Confirm that the attack infrastructure is being decrypted (TLS decryption/interception).Verify allowlists and inform the Red Team. Collaborate with the Red Team to test payloads and C2 on non-exercise systems prior to the exercise. Create an exercise case following the Digital Forensics and Incident Response (DFIR) process: This will facilitate tagging artifacts and adhering to normal procedures without raising flags for suspicious activity (e.g., pulling memory from a system without a formal case).Ensure that target systems are not segmented or wiped, as they will be utilized throughout the exercise. It is important to note that DFIR results can provide valuable insights for Cyber Threat Intelligence. Ensure that the appropriate forensic tools are deployed on the target systems. Install live forensic tools to enhance efficiency during the Purple Team Exercise, such as:
  - Sysmon: Sysmon, or System Monitor, is a Windows system service and device driver that logs system activity to the Windows Event Log. It provides detailed information about process creations, network connections, and file creation time, among other events. By capturing this data, Sysmon enhances visibility into system activities, aiding in threat detection and forensic investigations.
  - Process Monitor: Process Monitor is a powerful monitoring tool for Windows that combines the features of two older Sysinternals utilities, Filemon and Regmon. It provides real-time monitoring of file system, registry, and process/thread activity. This tool is invaluable for troubleshooting and analyzing system behaviour, allowing security professionals to identify malicious activities and understand application interactions in detail.

Fig 5 : 5.2.1 Hunt & Defend TeamWork.

5.3 Retesting

Retesting is an essential aspect of the cybersecurity lifecycle, particularly following security assessments, penetration tests, or Purple Team Exercises. It serves as a systematic approach to verify the effectiveness of security controls after vulnerabilities have been identified and remediated. The primary objective of retesting is to ensure that the implemented fixes adequately mitigate the previously discovered weaknesses and that no new vulnerabilities have been introduced during the remediation process.

The retesting process typically begins with the Red Team re-emulating the same Tactics, Techniques, and Procedures (TTPs) that were previously executed during the initial assessment. This allows organizations to validate whether their defenses can now detect and respond to these threats effectively. By simulating real-world attack scenarios, the Red Team can assess the current security posture and determine if the changes made have successfully addressed the identified vulnerabilities.

One of the key benefits of retesting is that it provides organizations with an opportunity for

continuous improvement within their security framework. By analyzing the outcomes of the retesting phase, organizations can identify areas for further enhancement, ensuring that their security posture evolves in response to the ever-changing threat landscape. This iterative process fosters a culture of proactive security, where organizations are not only focused on immediate fixes but are also committed to long-term resilience against cyber threats.

Moreover, retesting helps organizations refine their detection capabilities and improve incident response protocols. By understanding how well their security measures perform against known attack vectors, organizations can make informed decisions about resource allocation, training, and technology investments. This process also aids in building confidence among stakeholders, as it demonstrates a commitment to maintaining a robust security posture.

- In addition to validating the effectiveness of security controls, retesting can also uncover new vulnerabilities that may have emerged due to changes in the environment, such as software updates, system migrations, or the introduction of new technologies. This highlights the importance of ongoing vigilance and the need for regular assessments to ensure that security measures remain effective over time.
- Ultimately, retesting is crucial for maintaining resilience against cyber threats. It reinforces the importance of a proactive security culture and ensures that organizations are well-prepared to defend against future attacks. By incorporating retesting into their security strategy, organizations can continuously enhance their defenses, adapt to emerging threats, and safeguard their critical assets. Regular retesting not only helps in identifying and addressing vulnerabilities but also strengthens the overall security posture, fostering a more secure environment for operations.

CHAPTER 5

ENHANCEMENTS & FUTURE WORK

1. **Integration of Advanced Technologies:**

- Explore the use of artificial intelligence and machine learning to enhance threat detection and response capabilities. Implement automation tools to streamline the execution and tracking of TTPs during exercises.

2. **Expanded Cyber Threat Intelligence Sources:**

- Incorporate additional sources of Cyber Threat Intelligence, including industry-specific threat feeds and open-source intelligence. Establish partnerships with Information Sharing and Analysis Center (ISACs) for real-time threat updates.

3. **Enhanced Training Programs:**

- Develop comprehensive training modules for Red and Blue Team members to improve their skills in adversary emulation and defence strategies. Conduct regular workshops and simulations to keep teams updated on the latest threats and TTPs.

4. **Improved Documentation and Reporting:**

- Create standardized templates for documenting exercise results, lessons learned, and action items to ensure consistency. Implement a centralized repository for storing and accessing historical exercise data and reports.

5. **Feedback Mechanisms:**

- Establish formal feedback loops to gather insights from participants after each exercise, focusing on areas for improvement. Utilize surveys and interviews to assess the effectiveness of exercises and identify gaps in knowledge or skills.

6. **Continuous Purple Teaming Operations:**

- Transition from periodic exercises to continuous Purple Teaming operations to maintain a proactive security posture. Implement regular, smaller-scale exercises to test specific TTPs and improve real-time collaboration between teams.

7. **Cross-Functional Collaboration:**

- Foster collaboration between security teams and other departments (e.g., IT, compliance) to enhance overall organizational security. Encourage participation from non-security staff to raise awareness and improve incident response capabilities.

CHAPTER 6
CONCLUSION

The Purple Team Exercise Framework (PTEF) serves as a comprehensive guide for organizations aiming to enhance their cybersecurity posture through collaborative exercises between Red and Blue Teams. By fostering a culture of cooperation and continuous improvement, the PTEF enables organizations to effectively emulate adversarial tactics, techniques, and procedures (TTPs) that are relevant to their specific threat landscape. This structured approach not only helps in identifying vulnerabilities but also in refining the processes and technologies that underpin an organization's security operations.

One of the key strengths of the PTEF is its emphasis on Cyber Threat Intelligence (CTI). By leveraging actionable intelligence, organizations can tailor their exercises to reflect the most pertinent threats they face. This intelligence-driven methodology ensures that the exercises are not merely theoretical but grounded in real-world scenarios that adversaries are likely to exploit. The iterative nature of the exercises allows teams to continuously adapt and improve their defences, thereby increasing resilience against evolving threats.

The PTEF outlines a clear methodology that includes preparation, execution, and lessons learned phases. This structured approach ensures that all participants understand their roles and responsibilities, which is crucial for the success of the exercises. The involvement of various stakeholders, including management and operational teams, underscores the importance of a holistic approach to cybersecurity. By engaging different teams, organizations can break down silos and promote a unified defence strategy.

Moreover, the PTEF encourages organizations to document their findings and action items meticulously. This documentation not only serves as a record of the exercise but also provides valuable insights for future engagements. The emphasis on lessons learned fosters a culture of accountability and continuous improvement, which is essential in the fast-paced world of cybersecurity.

In conclusion, the Purple Team Exercise Framework is an invaluable resource for organizations seeking to bolster their cybersecurity defences. By promoting collaboration between Red and Blue Teams, leveraging Cyber Threat Intelligence, and following a structured methodology, organizations can effectively prepare for and respond to cyber threats. The PTEF not only enhances the technical capabilities of security teams but also cultivates a proactive security culture that is essential for navigating the complexities of today's threat landscape. As cyber threats continue to evolve, the PTEF provides a robust framework for organizations to stay ahead of adversaries and protect critical assets.

6.1 Exercise Workflow & Tracking

The Exercise Flow within the Purple Team Exercise Framework (PTEF) is meticulously designed to facilitate a structured and effective approach to adversary emulation. The process begins with the

presentation of the adversary, their Tactics, Techniques, and Procedures (TTPs), and the technical details surrounding the attack. This initial step is crucial as it sets the stage for the entire exercise.

- **Key Components of the Presentation:**
    - Adversary behaviour
    - Procedures employed
    - Tools used
    - Attack vectors
    - Delivery methods
    - Privileges that can be gained through the attack

This comprehensive overview ensures that all participants have a clear understanding of the threat landscape. Following the presentation, a collaborative discussion takes place among the Purple Team members regarding the expected controls based on the identified TTPs. This discussion involves the Security Operations Center (SOC), Hunt Team, and Digital Forensics and Incident Response (DFIR) teams, who share insights on logs, alerts, and documented methods for identifying the leveraged TTPs.

- **Collaborative Discussion Focus:**
    - SOC: Logs or alerts for the TTP
    - Hunt Team: Hunt cases related to the TTP
    - DFIR: Methods to identify if the TTP was leveraged

This collaborative effort is essential for aligning the teams' understanding and expectations. Once the groundwork is laid, the Red Team executes the TTP, providing critical information such as the attacker's IP address, the target, and the exact time of the attack. This execution is visually demonstrated, allowing all participants to observe the attack in real-time.

- **Execution Details:**
    - Attacker IP address
    - Target information
    - Exact time of the attack
    - Visual demonstration of the attack

The SOC, Hunt, and DFIR teams then follow their established processes to identify evidence of the TTP, with time being monitored to ensure the exercise progresses smoothly. As the exercise unfolds, participants share screens to discuss any identified TTPs, alerts, logs, or forensic evidence. This real-time analysis includes tracking the time taken to detect the TTP and the time to receive alerts.

- **Real-Time Analysis Focus:**
    - Time to detect the TTP

    - Time to receive alerts
    - Evidence collection and display

The Red Team may then stop the TTP, display the evidence collected, and rerun the TTP to further test the teams' responses. Documentation is a critical component of the exercise flow. Teams must record what worked and what did not, as well as any short-term adjustments that could enhance visibility.

- **Documentation Focus:**
    - What worked and what did not
    - Short-term adjustments for visibility
    - Feedback and action items for each TTP

Implementing these adjustments and repeating the TTP allows for continuous improvement. Tracking the exercise is equally important. A dedicated Exercise Coordinator is responsible for taking minutes, notes, and action items, as well as gathering feedback from attendees and sponsors.

- **Tracking Responsibilities:**
    - Taking minutes and notes
    - Gathering feedback from attendees and sponsors
    - Sending daily summary emails

Daily emails summarizing the exercise's progress and plans for the next day are sent to all participants. Tools like VECTR and DeTT&CT can be utilized for tracking and reporting, providing a structured way to monitor TTPs and enhance the overall effectiveness of the Purple Team Exercises.

CHAPTER 7

REFERENCES

1. Masdari, Mohammad, Nabavi, Sayyid, and Ahmadi, Vafa. “An Overview of Virtual Machine Placement Schemes in Cloud Coputing.” Journal of Network and Computer Applications, 66 (Jan. 2016), p. 32.

2. Combe, Theo, Martin, Antony, and Pietro, Roberto. “To Docker or Not to Docker: A Security Perspective.” IEEE Cloud Computing, 3 (Sept. 2016), pp. 54–62. DOI: 10.1109/MCC.2016.100.

3. Rameez, Asif, Ghanem, Kinan, and Irvine, James. “Containerization: For Over-the-Air Programming of Field Deployed Internet-of-Energy Based on Cost Effective LPWAN.” In 2020 First International Conference of Smart Systems and Emerging Technologies (SMARTTECH), 2020, pp. 65–70. DOI: 10.1109/SMART-TECH49988.2020.00030.

4. Dragoni, Nicola, Giallorenzo, Saverio, Lluch-Lafuente, Alberto, Mazzara, Manuel, Montesi, Fabrizio, Mustafin, Ruslan, and Safina, Larisa. “Microservices: Yesterday, Today, and Tomorrow.” (June 2016), p. 16.

5. Al-Mohannadi, Hamad, Mirza, Qublai, Namanya, Anitta, Awan, Irfan, Cullen, Andrea, and Disso, Jules. “Cyber-Attack Modeling Analysis Techniques: An Overview.” (2016), pp. 69–76.

6. Lavi, Lazarovitz. “Deconstructing the Solarwinds Breach.” Computer Fraud & Security, 2021.6 (2021), pp. 17–19. DOI: 10.1016/s1361-3723(21)00065-8.

7. Jayasinghe, Keshani, and Poravi, Guhanathan. “A Survey of Attack Instances of Cryptojacking Targeting Cloud Infrastructure.” In Proceedings of the 2020 2nd Asia Pacific Information Technology Conference (2020). DOI: 10.1145/3379310.3379323.

8. Hwang, Chan-Woong, Bae, Sung-Ho, and Lee, Tae-Jin. “MITRE ATT&CK and Anomaly Detection Based Abnormal Attack Detection Technology Research.” In Convergence Security Journal (2021), pp. 13–23.

9. Minna, Francesco, Blaise, Agathe, Rebecchi, Filippo, Chandrasekaran, Balakrishnan, and Massacci, Fabio. “Understanding the Security Implications of Kubernetes Networking.” IEEE Security &Privacy,19.5 (2021),pp.46–56.DOI: 10.1109/MSEC.2021.3094726.